

EVALUACIÓN DEL MÓDULO 10

Yosselinne Navarro

Captura 1: Despliegue del Laboratorio Aislado y Validación de Herramientas de Auditoría (CLI)

Demostración del entorno de pruebas controlado y confinado para la auditoría técnica de SecureVision S.A. Se evidencia la verificación de direccionamiento de red mediante `ip addr show`, confirmando la asignación de un segmento privado aislado provisto por el hipervisor para mitigar cualquier impacto colateral sobre redes en producción. Asimismo, se certifica la disponibilidad de las herramientas esenciales de diagnóstico y escaneo mediante `which`, garantizando el aprovisionamiento metodológico previo a la ejecución del pentesting.

```
Ingen-server login: adminingen
Password:
Welcome to Ubuntu 26.04.1 LTS (GNU/Linux 7.0.0-31-generic x86_64)

 * Documentation:  https://docs.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of mié 09 sept 2026 07:46:15 UTC

System load:          1.96
Usage of /:            33.6% of 19.52GB
Memory usage:         14%
Swap usage:           0%
Processes:            127
Users logged in:      0
IPv4 address for enp0s3: 10.0.2.15
IPv6 address for enp0s3: fd00::a00:27ff:fe74:fe21

 * Canonical Workshop gives developers fast, composable, reproducible, and
   secure developer environments that are perfect for agentic workflows.
   https://ubuntu.com/workshop

El mantenimiento de seguridad expandido para Applications está desactivado
Se pueden aplicar 5 actualizaciones de forma inmediata.
Para ver estas actualizaciones adicionales, ejecute: apt list --upgradable
Active ESM Apps para recibir futuras actualizaciones de seguridad adicionales.
Vea https://ubuntu.com/esm o ejecute «sudo pro status»

adminingen@Ingen-server:~$ ip addr show
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:74:fe:21 brd ff:ff:ff:ff:ff:ff
    altname enx08002774fe21
    inet 10.0.2.15/24 metric 100 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 86300sec preferred_lft 86300sec
    inet6 fd00::a00:27ff:fe74:fe21/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86301sec preferred_lft 14301sec
    inet6 fe80::a00:27ff:fe74:fe21/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
adminingen@Ingen-server:~$
```

Captura 2: Recopilación de Información Pasiva, Footprinting DNS y Fingerprinting Tecnológico (CLI)

Ejecución de la fase de reconocimiento sobre el perímetro digital asignado. Se exhibe la resolución de infraestructura mediante consultas a registros DNS autoritativos para determinar la exposición de hosts y servicios asociados. Paralelamente, se constata la captura e inspección de cabeceras HTTP de respuesta (HTTP Response Headers), permitiendo realizar el *fingerprinting* de la pila tecnológica (servidor web y runtime) sin alterar la operatividad ni generar anomalías en los registros del objetivo.

```
inet6 fe80::a00:87ff:fe74:fe21/64 scope link proto kernel_l1
valid_lft forever preferred_lft forever
adminingen@ingen-server:~$ host -t any example.com
example.com has IPv6 address 2606:4700:10::6814:179a
example.com has IPv6 address 2606:4700:10::ac42:93f3
example.com has address 172.66.147.243
example.com has address 104.20.23.154
adminingen@ingen-server:~$ curl -I -s https://example.com | grep -iE "(server|x-powered-by|content-type)"
content-type: text/html
server: cloudflare
adminingen@ingen-server:~$ traceroute -m 5 example.com 2>/dev/null || tracepath -m 5 example.com
-bash: /dev/null: Permission denied
 1:  [LOCALHOST]                pmtu 1500
 1:  _gateway                    497.868ms
 1:  _gateway                    491.869ms
 2:  no reply
 3:  no reply
 4:  no reply
 5:  no reply
    Too many hops: pmtu 1500
    Resume: pmtu 1500
adminingen@ingen-server:~$ traceroute -m 5 example.com 2>/dev/null || tracepath -m 5 example.com
 1:  [LOCALHOST]                pmtu 1500
 1:  _gateway                    323.625ms
 1:  _gateway                    51.751ms
 2:  no reply
 3:  no reply
 4:  no reply
 5:  no reply
    Too many hops: pmtu 1500
    Resume: pmtu 1500
adminingen@ingen-server:~$ echo "=== 1. REGISTROS DNS / FOOTPRINTING ==="
=== 1. REGISTROS DNS / FOOTPRINTING ===
adminingen@ingen-server:~$ host -t A example.com
example.com has address 172.66.147.243
example.com has address 104.20.23.154
adminingen@ingen-server:~$ echo ""

adminingen@ingen-server:~$ echo "=== 2. FINGERPRINTING DE SERVICIOS WEB ==="
=== 2. FINGERPRINTING DE SERVICIOS WEB ===
adminingen@ingen-server:~$ curl -I -s https://example.com | head -n 8
HTTP/2 200
date: Wed, 09 Sep 2026 07:51:39 GMT
content-type: text/html
server: cloudflare
last-modified: Sun, 30 Aug 2026 04:11:49 GMT
allow: GET, HEAD
accept-ranges: bytes
age: 439
adminingen@ingen-server:~$
```

Captura 3: Escaneo Activo de Puertos, Detección de Versiones y Mapeo de Sockets de Red (CLI)

Diagnóstico de la superficie de ataque perimetral mediante un escaneo SYN sigiloso (nmap -sS -sV) complementado con la auditoría de sockets de transporte locales (ss -tuln). La salida confirma la identificación certera de los puertos de red expuestos, sus respectivos protocolos de capa de transporte y las versiones específicas de software en escucha activa. Esta correlación técnica permite aislar servicios obsoletos o puertos innecesarios que representan potenciales vectores de entrada para actores de amenaza.

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.23 seconds
adminingen@ingen-server:~$ sudo nmap --script banner,ssl-cert -p 22,80,443 127.0.0.1
Starting Nmap 7.90 ( https://nmap.org ) at 2026-09-09 07:53 +0000
Stats: 0:00:03 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 75.00% done; ETC: 07:53 (0:00:01 remaining)
Stats: 0:00:03 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 75.00% done; ETC: 07:53 (0:00:01 remaining)
Debugging Increased to 1.
Stats: 0:00:04 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE: Active NSE Script Threads: 1 (1 waiting)
NSE Timing: About 75.00% done; ETC: 07:53 (0:00:01 remaining)
NSE: Script banner: 0 threads running, 1 threads waiting
NSE: [banner 127.0.0.1:80] failed for 127.0.0.1 on tcp port 80. Message: The script encountered an error:
- tryssl failed:
- ssl failed:
- Failed to connect:
- Could not connect:
- ERROR
NSE: Finished banner against 127.0.0.1:80.
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000033s latency).
Scanned at 2026-09-09 07:53:31 UTC for 10s

PORT      STATE SERVICE
22/tcp    open  ssh
|_banner: SSH-2.0-OpenSSH_10.2p1 Ubuntu-2ubuntu3.6
80/tcp    open  http
443/tcp   closed https
Final times for host: srth: 33 rttvar: 2824 to: 100000

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 1) scan.
Read from /usr/bin/./share/nmap: nmap-protocols nmap-services.
Nmap done: 1 IP address (1 host up) scanned in 10.10 seconds
adminingen@ingen-server:~$ sudo ss -tulnp
Netid State  Recv-Q Send-Q      Local Address:Port      Peer Address:Port  Process
udp    UNCONN  0      0      127.0.0.54:53            0.0.0.0:*          users:(("systemd-resolve",pid=491,fd=18))
udp    UNCONN  0      0      127.0.0.53%lo:53         0.0.0.0:*          users:(("systemd-resolve",pid=491,fd=16))
udp    UNCONN  0      0      10.0.2.15%enp0s3:68      0.0.0.0:*          users:(("systemd-network",pid=820,fd=30))
udp    UNCONN  0      0      127.0.0.1:323           0.0.0.0:*          users:(("chronyd",pid=1037,fd=4))
udp    UNCONN  0      0      [::]:323                [::]:*            users:(("chronyd",pid=1037,fd=5))
tcp    LISTEN  0      4096      127.0.0.53%lo:53         0.0.0.0:*          users:(("systemd-resolve",pid=491,fd=17))
tcp    LISTEN  0      4096      0.0.0.0:22              0.0.0.0:*          users:(("sshd",pid=1549,fd=3),("systemd",pid=1,fd=103))
tcp    LISTEN  0      4096      127.0.0.54:53           0.0.0.0:*          users:(("systemd-resolve",pid=491,fd=19))
tcp    LISTEN  0      511          *:80                    *:*              users:(("apache2",pid=1093,fd=4),("apache2",pid=1092,fd=4),("apache2",pid=934,fd=4))
tcp    LISTEN  0      4096      [::]:22                 [::]:*            users:(("sshd",pid=1549,fd=4),("systemd",pid=1,fd=104))
tcp    LISTEN  0      32          *:21                    *:*              users:(("vsftpd",pid=969,fd=3))
```

Captura 4: Análisis de Vectores de Escalamiento de Privilegios y Mecanismos de Persistencia (CLI)

Evaluación técnica orientada a la fase de explotación y post-explotación en sistemas comprometidos. Se documenta la auditoría de privilegios administrativos mediante la lectura de políticas en `/etc/sudoers` (`sudo -l`), el escrutinio de binarios del sistema con el bit SUID activo (`find -perm -4000`) susceptibles a técnicas de secuestro de privilegios, y la inspección de directorios de tareas programadas (`/etc/cron*`) como potenciales canales para el establecimiento de persistencia no autorizada.

```
adminingen@ingen-server:~$
adminingen@ingen-server:~$
adminingen@ingen-server:~$
adminingen@ingen-server:~$
adminingen@ingen-server:~$
adminingen@ingen-server:~$
adminingen@ingen-server:~$
adminingen@ingen-server:~$ sudo -l
User adminingen may run the following commands on ingen-server:
    (ALL : ALL) ALL
adminingen@ingen-server:~$ find /usr/bin -perm -400 -type f 2>/dev/null | head -n 6
/usr/bin/ucf
/usr/bin/ntfsfix
/usr/bin/rdma
/usr/bin/sg_stream_ctl
/usr/bin/grub-mkfont
/usr/bin/hue-support-status
adminingen@ingen-server:~$ crontab -l 2>/dev/null || echo "No crontab for current user"
No crontab for current user
adminingen@ingen-server:~$ ñs -l /etc/cron.daily | head -n 4
ñs: command not found
adminingen@ingen-server:~$ ls -l /etc/cron.daily | head -n 4
total 24
-rwxr-xr-x 1 root root 539 Aug 11 2025 apache2
-rwxr-xr-x 1 root root 376 Jul 3 11:16 apport
-rwxr-xr-x 1 root root 1478 Apr 7 09:02 apt-compat
adminingen@ingen-server:~$ echo "=== 1. AUDITORIA DE REGLAS SUDO (VECTORES DE PRIVILEGIOS) ==="
=== 1. AUDITORIA DE REGLAS SUDO (VECTORES DE PRIVILEGIOS) ===
adminingen@ingen-server:~$ sudo -l | tail -n 4
User adminingen may run the following commands on ingen-server:
    (ALL : ALL) ALL
adminingen@ingen-server:~$ echo ""

adminingen@ingen-server:~$ echo "=== 2. DETECCION DE BINARIOS CON BIT SUID (ESCUDIRINAMIENTO) ==="
=== 2. DETECCION DE BINARIOS CON BIT SUID (ESCUDIRINAMIENTO) ===
adminingen@ingen-server:~$ find /usr/bin -perm -4000 -type f 2>/dev/null | head -n 5
adminingen@ingen-server:~$ echo ""

adminingen@ingen-server:~$ echo "=== 3. REVISION DE TAREAS PROGRAMADAS (PERSISTENCIA) ==="
=== 3. REVISION DE TAREAS PROGRAMADAS (PERSISTENCIA) ===
adminingen@ingen-server:~$ ls -ld /etc/cron*
drwxr-xr-x 2 root root 4096 Aug 26 05:01 /etc/cron.d
drwxr-xr-x 2 root root 4096 Sep 9 03:46 /etc/cron.daily
drwxr-xr-x 2 root root 4096 Aug 26 05:01 /etc/cron.hourly
drwxr-xr-x 2 root root 4096 Aug 26 05:01 /etc/cron.monthly
drwxr-xr-x 2 root root 4096 Aug 26 05:01 /etc/cron.weekly
drwxr-xr-x 2 root root 4096 Aug 26 05:01 /etc/cron.yearly
-rw-r--r-- 1 root root 1136 Nov 5 2025 /etc/crontab
adminingen@ingen-server:~$
```

Captura 5: Seguridad en Aplicaciones Web, Mitigación de Inyección SQL y Sanitización XSS (CLI)

Validación en consola de los controles defensivos frente a las vulnerabilidades críticas del estándar OWASP Top 10. Se exhibe el contraste directo entre una consulta SQL susceptible a concatenación arbitraria y su remediación estricta mediante sentencias parametrizadas (*prepared statements*), demostrando la neutralización de cargas booleanas maliciosas. Simultáneamente, se valida la mitigación de Cross-Site Scripting (XSS) mediante la codificación de entidades HTML (HTML Entity Encoding), impidiendo la ejecución de scripts no confiables en el navegador del cliente.

```
/usr/bin/rdma
/usr/bin/sg_stream_ctl
/usr/bin/grub-mkfont
/usr/bin/hw-usb-support-status
adminingen@ingen-server:~$ crontab -l 2>/dev/null || echo "No crontab for current user"
No crontab for current user
adminingen@ingen-server:~$ ls -l /etc/cron.daily | head -n 4
ls: command not found
adminingen@ingen-server:~$ ls -l /etc/cron.daily | head -n 4
total 24
-rwxr-xr-x 1 root root 539 Aug 11 2025 apache2
-rwxr-xr-x 1 root root 376 Jul 3 11:16 apport
-rwxr-xr-x 1 root root 1478 Apr 7 09:02 apt-compat
adminingen@ingen-server:~$ echo "=== 1. AUDITORIA DE REGLAS SUDO (VECTORES DE PRIVILEGIOS) ==="
=== 1. AUDITORIA DE REGLAS SUDO (VECTORES DE PRIVILEGIOS) ===
adminingen@ingen-server:~$ sudo -l | tail -n 4
User adminingen may run the following commands on ingen-server:
  (ALL : ALL) ALL
adminingen@ingen-server:~$ echo ""

adminingen@ingen-server:~$ echo "=== 2. DETECCION DE BINARIOS CON BIT SUID (ESCUDRINAMIENTO) ==="
=== 2. DETECCION DE BINARIOS CON BIT SUID (ESCUDRINAMIENTO) ===
adminingen@ingen-server:~$ find /usr/bin -perm -4000 -type f 2>/dev/null | head -n 5
adminingen@ingen-server:~$ echo ""

adminingen@ingen-server:~$ echo "=== 3. REVISION DE TAREAS PROGRAMADAS (PERSISTENCIA) ==="
=== 3. REVISION DE TAREAS PROGRAMADAS (PERSISTENCIA) ===
adminingen@ingen-server:~$ ls -ld /etc/cron*
drwxr-xr-x 2 root root 4096 Aug 26 05:01 /etc/cron.d
drwxr-xr-x 2 root root 4096 Sep 9 03:46 /etc/cron.daily
drwxr-xr-x 2 root root 4096 Aug 26 05:01 /etc/cron.hourly
drwxr-xr-x 2 root root 4096 Aug 26 05:01 /etc/cron.monthly
drwxr-xr-x 2 root root 4096 Aug 26 05:01 /etc/cron.weekly
drwxr-xr-x 2 root root 4096 Aug 26 05:01 /etc/cron.yearly
-rw-r--r-- 1 root root 1136 Nov 5 2025 /etc/crontab
adminingen@ingen-server:~$ python3 -c "import html; p='admin' OR '1'='1'"; print('VULN SQL:', f'SELECT * FROM users WHERE user='{p}'); print('SAFE SQL: SELECT * FROM users WHERE user={p}'); print('SAFE XSS:', html.escape('<script>alert(1)</script>'))"
>
> python3 -c "import html; p='admin' OR '1'='1'"; print('VULN SQL:', f'SELECT * FROM users WHERE user='{p}'); print('SAFE SQL: SELECT * FROM users WHERE user={p}'); print('SAFE XSS:', html.escape('<script>alert(1)</script>'))"
-bash: syntax error near unexpected token `('
adminingen@ingen-server:~$ python3 -c "import html; p='admin' OR '1'='1'"; print('VULN SQL:', f'SELECT * FROM users WHERE user='{p}'); print('SAFE SQL: SELECT * FROM users WHERE user={p}'); print('SAFE XSS:', html.escape('<script>alert(1)</script>'))"
CT * FROM users WHERE user={p} | Param: ('p,'); print('SAFE XSS:', html.escape('<script>alert(1)</script>'))
> x"C
adminingen@ingen-server:~$ python3 -c "import html; p='admin' OR '1'='1'"; print('VULN SQL:', f'SELECT * FROM users WHERE user='{p}'); print('SAFE SQL: SELECT * FROM users WHERE user={p}'); print('SAFE XSS:', html.escape('<script>alert(1)</script>'))"
VULN SQL: SELECT * FROM users WHERE user='admin' OR '1'='1'
SAFE SQL: SELECT * FROM users WHERE user={p} | Param: ('admin' OR '1'='1',)
SAFE XSS: &lt;script&gt;alert(1)&lt;/script&gt;
adminingen@ingen-server:~$
```

Captura 6: Evaluación de Seguridad Inalámbrica y Migración a Estándares WPA3 Enterprise (CLI)

Diagnóstico de los protocolos de seguridad en redes inalámbricas corporativas. Se evidencia la verificación de utilidades para captura e inspección de tramas 802.11, acompañada de un análisis sobre la debilidad estructural del intercambio de cuatro vías (*4-Way Handshake*) característico de WPA2-Personal (PSK). Como medida de fortificación institucional, se formaliza la propuesta técnica de transición hacia el protocolo WPA3-Enterprise sustentado en el estándar 802.1X, autenticación centralizada mediante servidores RADIUS y cifrado robusto bajo EAP-TLS.

[illegible]

Captura 7: Análisis Forense de Vector de Phishing y Protocolo de Respuesta Institucional (CLI)

Simulación técnica para la detección y neutralización de incidentes originados por manipulación humana e ingeniería social. La evidencia exhibe la auditoría de cabeceras de correo electrónico detectando spoofing de identidad y verificaciones fallidas de autenticidad en los registros SPF, DKIM y DMARC. Como respuesta coordinada del Centro de Operaciones de Seguridad (SOC), se documenta el bloqueo perimetral del dominio atacante mediante *DNS Sinkholing* y la activación de programas continuos de concientización y reporte rápido para colaboradores.

[illegible]